

SECURITY INCIDENT REPORT

AWS GuardDuty Threat Detection Lab

Home Lab Portfolio Project | Blue Team / Cloud Security

1. Incident Metadata

Report Title	AWS GuardDuty Threat Detection — Simulated Cloud Incident Investigation
Incident ID	INC-2026-0428-001
Date	April 28, 2026
Analyst	Bryan Sykes
AWS Account ID	XXX477310XXX (masked for public repo)
AWS Region	us-east-1 (US East — N. Virginia)
Detection Tool	Amazon GuardDuty (30-Day Trial)
Logging Tool	AWS CloudTrail (guardduty-lab-trail)
Severity	CRITICAL — High (Multiple finding types detected)
Status	Closed — Simulated lab environment. No live infrastructure affected.

2. Executive Summary

This report documents a simulated cloud security incident investigation conducted in a personal AWS lab environment using Amazon GuardDuty and AWS CloudTrail. The lab was designed to demonstrate cloud threat detection, finding triage, log analysis, and incident documentation skills aligned with blue team and SOC analyst job requirements.

GuardDuty was enabled and sample findings were generated to simulate realistic attacker behavior across two primary threat scenarios: EC2 instance credential exfiltration and a multi-stage EC2 instance group compromise. Both scenarios were investigated using GuardDuty finding details and corroborating CloudTrail event logs. Findings were triaged, classified, and documented as a formal incident report.

Key takeaway: GuardDuty successfully detected two distinct attack patterns — a credential theft scenario and a coordinated multi-stage attack chain across nine EC2 instances — demonstrating the value of continuous cloud threat monitoring combined with CloudTrail audit logging for post-incident investigation.

3. Lab Environment

The following AWS services were configured for this investigation:

Service	Configuration / Purpose
Amazon GuardDuty	Enabled in us-east-1. 30-day free trial. Ingests VPC Flow Logs, CloudTrail, and DNS logs to generate threat findings.
AWS CloudTrail	Trail: guardduty-lab-trail. Logs all management events (Read + Write) to a dedicated S3 bucket. Provides raw API call audit trail for cross-referencing GuardDuty findings.
AWS S3	Auto-provisioned bucket for CloudTrail log storage. Bucket policy and encryption applied automatically by AWS.

4. Finding 1 — Credential Exfiltration (High Severity)

4.1 Finding Summary

Finding Type	UnauthorizedAccess:IAMUser/InstanceCredentialExfiltration.OutsideAWS
Severity	HIGH
Resource Affected	EC2 Instance — Access Key: GeneratedFindingAccessKeyId
Action Detected	AWS_API_CALL made using instance credentials from an external IP
Actor IPv4	198.51.100.0 (RFC 5737 documentation range — simulated)
Actor IPv6	1234:5678:90ab:cdef:1234:5678:90ab:cde0 (simulated)

4.2 What This Finding Means

EC2 instances are assigned temporary credentials via the AWS Instance Metadata Service (IMDS). These credentials are intended to be used only from within the instance. This finding triggers when GuardDuty detects those instance credentials being used from an IP address outside the EC2 instance — indicating the credentials were stolen and are being leveraged by an external threat actor.

The OutsideAWS variant (investigated here) is the more severe scenario: the stolen credentials are being used from a completely external network, not from another AWS resource. This is a common technique in real-world cloud breaches and is associated with MITRE ATT&CK technique T1552.005 — Cloud Instance Metadata API.

4.3 Analyst Notes — IP Address Analysis

The actor IP address (198.51.100.0) falls within the RFC 5737 TEST-NET-3 reserved documentation range. This is expected behavior for GuardDuty sample findings — AWS intentionally uses reserved ranges so simulated findings never point to live infrastructure.

In a real incident, this IP would be immediately pivoted on using threat intelligence tools including:

- AbuseIPDB — check for known malicious reports
- VirusTotal — cross-reference against known threat actor infrastructure
- Shodan — identify what services are running on the IP
- WHOIS / ASN lookup — identify hosting provider and geolocation

4.4 Recommended Response Actions

- Immediately disable the compromised IAM access key via the IAM console
- Pivot to CloudTrail Event History and filter by the compromised Access Key ID to identify all API calls made during the window of compromise
- Assess blast radius — identify every AWS resource the access key touched (S3 buckets read, EC2 actions, IAM changes, etc.)
- Rotate all credentials associated with the affected instance profile
- Enforce IMDSv2 on all EC2 instances to prevent future SSRF-based credential theft
- Review VPC Flow Logs for outbound data transfer volume during the incident window

4.5 CloudTrail Corroboration

CloudTrail Event History confirmed 45 management events during the lab session, including CreateSampleFindings (GuardDuty), CreateTrail, StartLogging, CreateBucket, and PutBucketPolicy. All events were attributed to the root user, confirming the activity originated from the lab operator and not an external actor. In a live incident, any events attributed to the compromised Access Key ID would be isolated and reviewed as potentially attacker-controlled.

5. Finding 2 — EC2 Instance Group Compromise (Critical Severity)

5.1 Finding Summary

Finding Type	AttackSequence:EC2/CompromisedInstanceGroup
Severity	CRITICAL
Resource Affected	Auto Scaling Group: sample-asg-name (9 EC2 instances)
Finding ID	a53722e3a9a3405d868d6b0e65980c03
Signals Detected	3 correlated signals across multiple instances
MITRE Tactics	Command and Control, Exfiltration, Impact

5.2 What Makes This Finding Unique

Unlike standard GuardDuty findings that detect a single suspicious event, AttackSequence findings leverage GuardDuty's machine learning correlation engine to identify multiple related

signals across time and resources, recognizing them as a coordinated attack chain rather than isolated anomalies. This is GuardDuty's most advanced detection capability.

This finding identified a complete ransomware-style kill chain across an entire EC2 Auto Scaling Group of 9 instances, progressing through three distinct MITRE ATT&CK tactics:

5.3 Attack Chain — Signal Timeline

Phase	MITRE Tactic	Observed Behavior
Signal 1	Command & Control	Instance i-0d5364d29fd4c8abe queried a blackholed domain name. Malware on the instance is beaconing to a C2 server — a domain sinkholed by threat intelligence feeds, indicating active malware infection and attacker control.
Signal 2	Exfiltration	Instance i-1d5364d29fd4c8abc queried a Drop Point domain — the attacker's data collection server. This indicates active data theft is occurring, with stolen data being staged for exfiltration to external infrastructure.
Signal 3	Impact	Instance i-2d5364d29fd4c8abc communicating with a known abused domain. This is the active damage phase — consistent with ransomware detonation, cryptomining deployment, or data destruction activity.

5.4 Blast Radius Assessment

GuardDuty identified 9 EC2 instances across one Auto Scaling Group (sample-asg-name) as potentially compromised. In a production environment, this scenario would represent a catastrophic breach — an attacker with persistent access across an entire compute fleet, capable of lateral movement to any resource those instances can reach within the VPC.

5.5 Recommended Response Actions

- Immediately isolate all 9 affected EC2 instances by modifying their security group rules to deny all inbound and outbound traffic
- Do NOT terminate instances before forensic evidence is captured — preserve memory and disk for investigation
- Take EBS snapshots of all affected instance volumes before any remediation
- Revoke all IAM roles and credentials associated with the affected Auto Scaling Group
- Audit all resources reachable from the compromised instances within the VPC — databases, S3 buckets, internal APIs
- Engage incident response team and notify stakeholders per the organization's IRP — this is a Critical severity event
- After containment: rebuild the Auto Scaling Group from a known-good AMI; do not attempt to clean the compromised instances

- Post-incident: conduct a root cause analysis to determine initial access vector and implement preventive controls

6. False Positive Analysis

During the lab session, a Low severity finding was generated prior to the sample findings batch. This finding was triggered by the creation of the CloudTrail trail and associated S3 bucket — legitimate administrative activity that GuardDuty flagged as slightly anomalous on a quiet account with no prior activity baseline.

This is a textbook false positive scenario. The finding was correctly classified as Low severity and, with context from CloudTrail confirming the activity was performed by the root user during known lab setup, would be closed as a false positive in a real SOC workflow. Key lesson: GuardDuty findings must always be cross-referenced against CloudTrail and environmental context before escalation. Alert volume without triage discipline leads to alert fatigue.

7. Key Technical Takeaways

- GuardDuty operates as an agentless detection service — no software is installed on monitored instances. It ingests VPC Flow Logs, CloudTrail management events, and Route 53 DNS logs natively.
- AttackSequence findings demonstrate ML-based correlation across multiple signals and resources — a capability that goes beyond signature-based detection and is critical for identifying sophisticated, multi-stage attacks.
- CloudTrail provides the audit trail that transforms a GuardDuty finding from an alert into an investigation — without logs, there is nothing to pivot on. GuardDuty detects; CloudTrail explains.
- Instance credential exfiltration (InstanceCredentialExfiltration) is one of the most common real-world cloud attack techniques. IMDSv2 enforcement is the primary preventive control.
- False positive triage is a core SOC analyst skill. A finding is not an incident until context confirms it. Always cross-reference the detection source against available log data before escalating.
- The root account was used for this lab. In production environments, all operations should be performed via IAM users and roles with least-privilege policies. The root account should be locked down with MFA and never used for routine tasks.

8. Conclusion

This lab demonstrated end-to-end cloud threat detection and incident investigation workflow using Amazon GuardDuty and AWS CloudTrail. Two distinct threat scenarios were identified, triaged, and documented: a high-severity credential exfiltration event and a critical multi-stage EC2 instance group compromise representing a complete ransomware-style attack chain.

The investigation confirmed GuardDuty's capability as a continuous, agentless cloud threat detection service and validated CloudTrail as the essential corroborating log source for cloud incident investigation. Both tools operate within the AWS shared responsibility model and require analyst expertise to convert findings into actionable incident response — a skill demonstrated throughout this report.

Report prepared by: **Bryan Sykes** | April 28, 2026 | Home Lab Portfolio Project — AWS GuardDuty Threat Detection